

DEVSECOPS ENGINEER · TECHNICAL ASSESSMENT

Multi-Cloud Platform Security & Compliance

Track 2 Governance Panel Review — Findings, Target-State Design & Remediation Roadmap

Reference workload: **terragoat (bridgecrewio)** — AWS · Azure · GCP

Presented to: **Programme Governance Panel**

Session: **25-minute presentation + 20-minute panel Q&A**

What We'll Cover in 25 Minutes

01

Executive Summary

Overall risk posture, in plain language

02

Top Findings & Prioritisation

What matters most, and why the rest can wait

03

Target-State Design

Identity, network and data protection as one story

04

Architecture (HLD & LLD)

The design a panel — and an engineer — can act on

05

COTS Exception & Residual Risk

The decision this panel needs to make today

06

Roadmap & Close

What the first stretch of delivery actually looks like

The Estate Is Functional but Not Yet Governed

Across the ~100-workload estate, controls exist in pockets rather than as a consistent baseline. The sampled review found exploitable, high-impact gaps concentrated in a small number of repeatable patterns — not one-off mistakes. None of them require exotic fixes; all of them require a pipeline and governance model that stops them recurring as Azure and GCP come online.

27

findings logged

4

critical severity

~100

workloads in estate

0

centralised detection today

Bottom line for the panel

Go-live is achievable this quarter for the sampled scope, provided: (1) the four critical findings are remediated or formally risk-accepted before sign-off, (2) the shift-left pipeline is in place to stop recurrence, and (3) the one COTS exception is accepted with compensating controls and a time-bound plan — not treated as a precedent.

How This Review Was Run

Reference target

Forked bridgecrewio/terragoat — the only shortlisted option spanning AWS, Azure and GCP in one codebase, matching this track's multi-cloud direction.

Why not the real estate

The production Terraform/cloud codebase is confidential; findings and patterns here are mapped 1:1 onto the equivalent misconfigurations from the audit scenario.

Severity methodology

Likelihood × blast radius × compliance exposure, adjusted for remediation effort — documented in severity-methodology.md so panel and engineers score consistently.

Coverage Achieved

Providers touched

AWS, Azure, GCP (2 of 3 fully; GCP partial per repo depth)

Resource domains

Storage, database, IAM, compute/network, logging, backup

Findings register

27 findings, 5 severities → severity-methodology.md

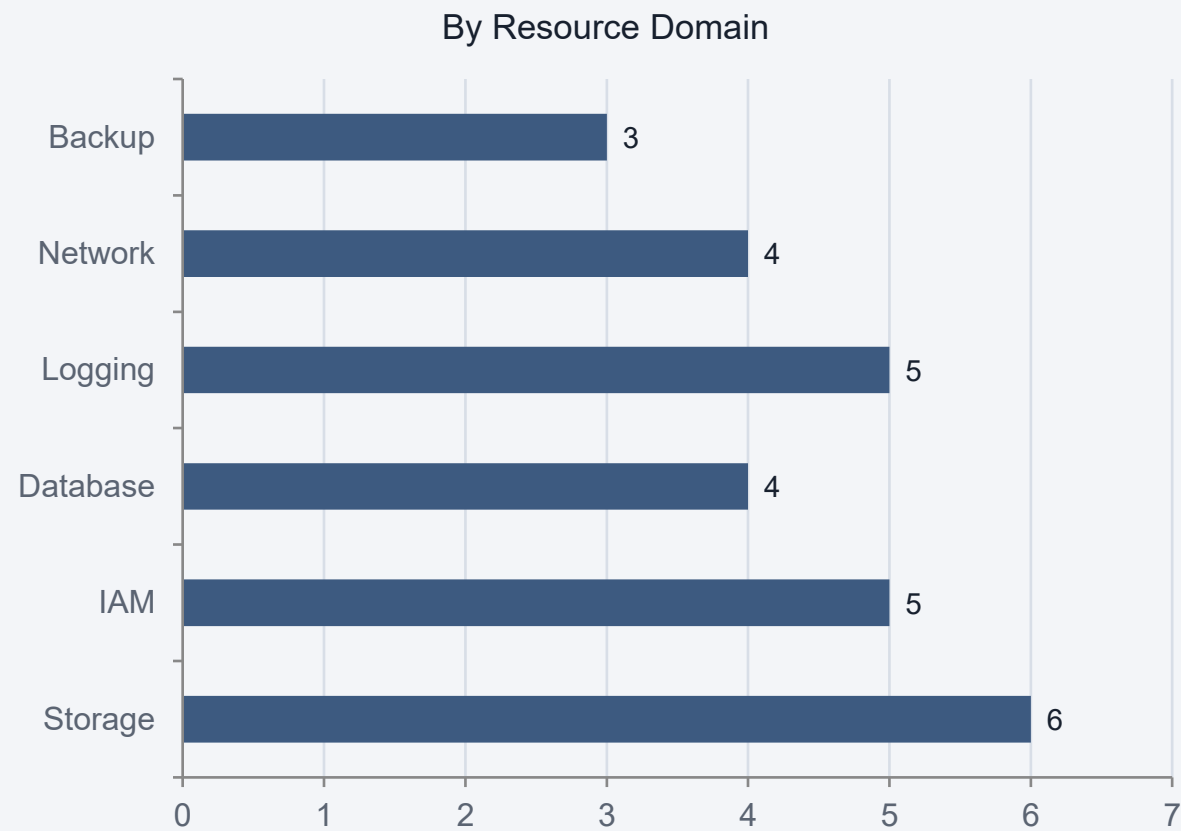
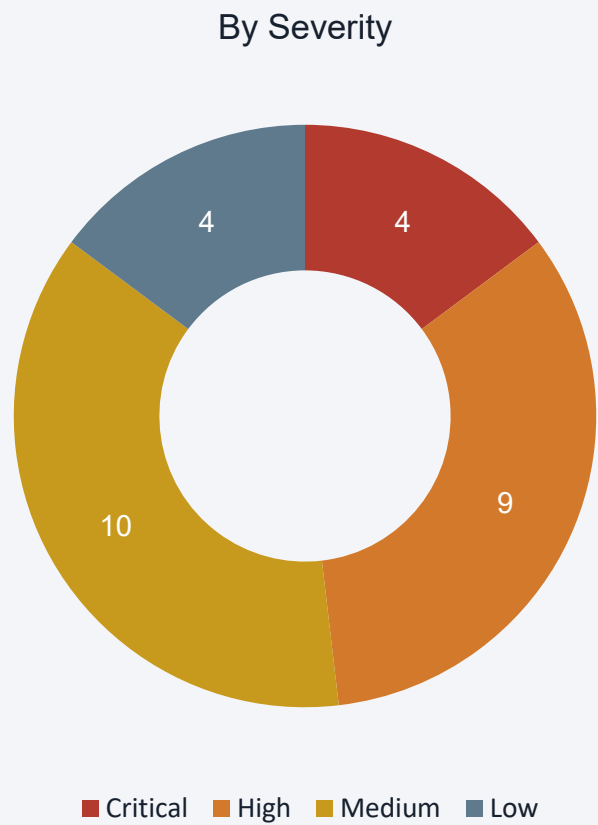
Modules delivered

13 of 13 — findings through DR, plus HLD/LLD

Repo hygiene

Incremental commits per module, no secrets in history

27 Findings, Concentrated in Four Patterns



Pattern, not chance: the same four gaps — public/unencrypted data stores, over-permissioned CI identity, inconsistent logging, and missing detection — reappear across storage, database and IAM findings alike.

The Five Findings That Set the Agenda

CRITICAL

Public + unencrypted storage buckets

Two S3-equivalent buckets with public access controls disabled; one holds application logs with embedded identifiers.

CRITICAL

Database publicly accessible, encryption-at-rest off

Managed DB instance reachable from the internet with no encryption at rest — direct exfiltration and tamper path.

CRITICAL

Wildcard IAM policy on CI service account

action:* / resource:* attached to the pipeline identity — the single highest blast-radius finding in the estate.

HIGH

Inconsistent audit logging coverage

Several accounts have no trail shipped anywhere reviewable — the compromise above would be invisible without it.

HIGH

Hardcoded credentials in Terraform variables

Static secrets committed in plaintext .tfvars — rotates the moment it's found, but signals a wider pattern.

Why These Five, and Why the Rest Can Wait

With ~100 workloads and limited remediation bandwidth, findings are scored on exploitability and blast radius first, compliance exposure second, and remediation effort last — effort informs sequencing, not whether something matters.

Internet-reachable + no auth boundary	Fix before go-live
High blast radius (CI/pipeline identity, shared KMS key)	Fix before go-live
Compliance-mapped control with audit exposure	Fix within quarter
Legacy/COTS constrained, low exploitability	Compensating control + residual risk
Low blast radius, isolated workload	Backlog, tracked

One Identity Model Across Three Clouds

Cross-cloud workload identity federation



No long-lived cross-cloud credentials anywhere. GitLab CI presents an OIDC token per job; each cloud's native federation trusts the token subject/claims and issues a short-lived, scoped role — the same pattern regardless of provider.

Wildcard CI Finding — Redesigned

Before: Action:* / Resource:* on the CI service account.

After: Per-pipeline role scoped to: plan/apply on named state buckets, tag-restricted resource creation, deny on IAM/KMS admin actions, and a separate break-glass role for emergency apply — approval-gated and time-boxed to 4 hours.

Human & Privileged Access

- Least-privilege baseline; standing admin access eliminated
- Admin-level access is approval-gated and time-bound (JIT/PIM-style), not standing
- Break-glass access is logged, alerts the ITSO-equivalent on use, and requires post-use justification
- One identity governance model reviewed centrally — not three parallel IAM strategies

Segmentation That Works the Same Way on Every Cloud

Public edge

Load balancer / API gateway only. No workload sits directly on the public internet.

Application tier

Segmented per workload sensitivity; east-west traffic denied by default, allow-listed by service.

Data tier

No direct internet route in or out; reachable only from the application tier via private endpoints.

Public → App → Data — the same three-tier posture is enforced whether the provider is AWS, Azure or GCP; only the primitive names change (SG vs NSG vs VPC firewall rule).

Cross-cloud connectivity

Transit-gateway-equivalent hub per provider, peered privately between clouds — no workload traffic ever transits the public internet between AWS, Azure and GCP.

Egress control

Default-deny egress with an explicit allow-list per workload; COTS/legacy systems get narrow, documented exceptions rather than open egress.

One network philosophy

A single segmentation and naming model (tiering, tagging, allow-list format) is defined once and implemented per-provider primitive — not redesigned per cloud.

Encryption, Key Ownership, and the COTS Gap

Key management approach

Cloud-native KMS per provider (AWS KMS / Azure Key Vault / GCP Cloud KMS), centrally governed through consistent key policy, rotation and access-logging standards. A single cross-cloud KMS was rejected — it trades operational simplicity for a single compromise point with blast radius across all three clouds at once.

- ▶ **Restricted / regulated:** CMK per workload, BYOK where the data owner requires it, strictest logging
- ▶ **Internal / sensitive:** Provider-managed CMK, standard rotation, access logged
- ▶ **General / low sensitivity:** Provider default encryption, standard controls

THE COTS GAP

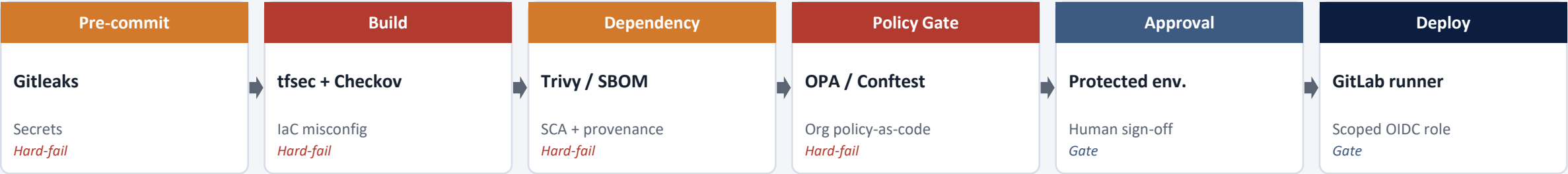
Financial reconciliation tool — driver can't operate with storage encryption enabled

This is not solved by re-encrypting harder — it's a vendor driver limitation that survives until re-platforming. The answer is compensating controls around the gap, a residual risk rating the panel formally accepts, and a deadline that keeps this from becoming a template for other exceptions. Full detail on slide 16.

Data residency note

Government workloads are pinned to in-region storage and KMS per provider; cross-region replication is opt-in per workload, never a default, and reviewed against residency requirements before enabling.

A Pipeline That Would Have Caught Every Audit Finding



Hard-fail vs. soft-fail

Secrets, critical IaC misconfig, and policy-as-code violations block the merge outright. New/low-severity SCA findings warn and file a ticket first — hard-failing every dependency finding on day one would stall ~100 workloads' worth of pipelines before the backlog is triaged.

Scaling to ~100 workloads

Tiered review depth by workload criticality: Tier-1 (internet-facing, regulated data) gets full-depth scanning every run; Tier-2/3 uses risk-based sampling with full scans on a schedule — kept honest by the CSPM continuously watching drift between scans (Module 6).

Multi-cloud onboarding: the gates don't change — tfsec/Checkov and OPA policies gain Azure/GCP rule packs, and the OIDC deploy step swaps in the relevant cloud's federation target. Same pipeline, same gates, new provider plugged in.

From Zero Centralised Detection to Continuous Coverage

CSPM	Continuous configuration monitoring across AWS/Azure/GCP; drift from the policy-as-code baseline raises a finding automatically, not at the next audit.
Centralised telemetry	CloudTrail / Activity Log / Cloud Audit Logs, plus VPC flow logs, shipped to one SIEM; retention and access aligned to the data classification tiers.
Alert-fatigue control	Findings correlated against asset criticality before paging — a wildcard IAM change on a Tier-1 CI account pages immediately, a low-tier tagging drift does not.

Incident scenario — CI service account confirmed compromised

1. Detect Anomalous API calls from CI identity to a DB outside its normal footprint trigger a Tier-1 correlation alert.	2. Contain Role's session revoked, credentials rotated, affected DB isolated at the network layer within minutes.	3. Eradicate Wildcard policy replaced with scoped role (slide 8); forensic snapshot taken before any cleanup.	4. Recover Service restored from verified-clean state; post-incident report and lessons-learned filed.
---	---	---	--

Two Different Messages for Two Different Moments

WHILE IT'S UNFOLDING

Short, factual, time-stamped updates to the ITSO-equivalent: what's confirmed, what's still unknown, what's been contained, and the next update time. No speculation on root cause and no premature all-clear. Cadence: every 30 minutes until contained, then hourly.

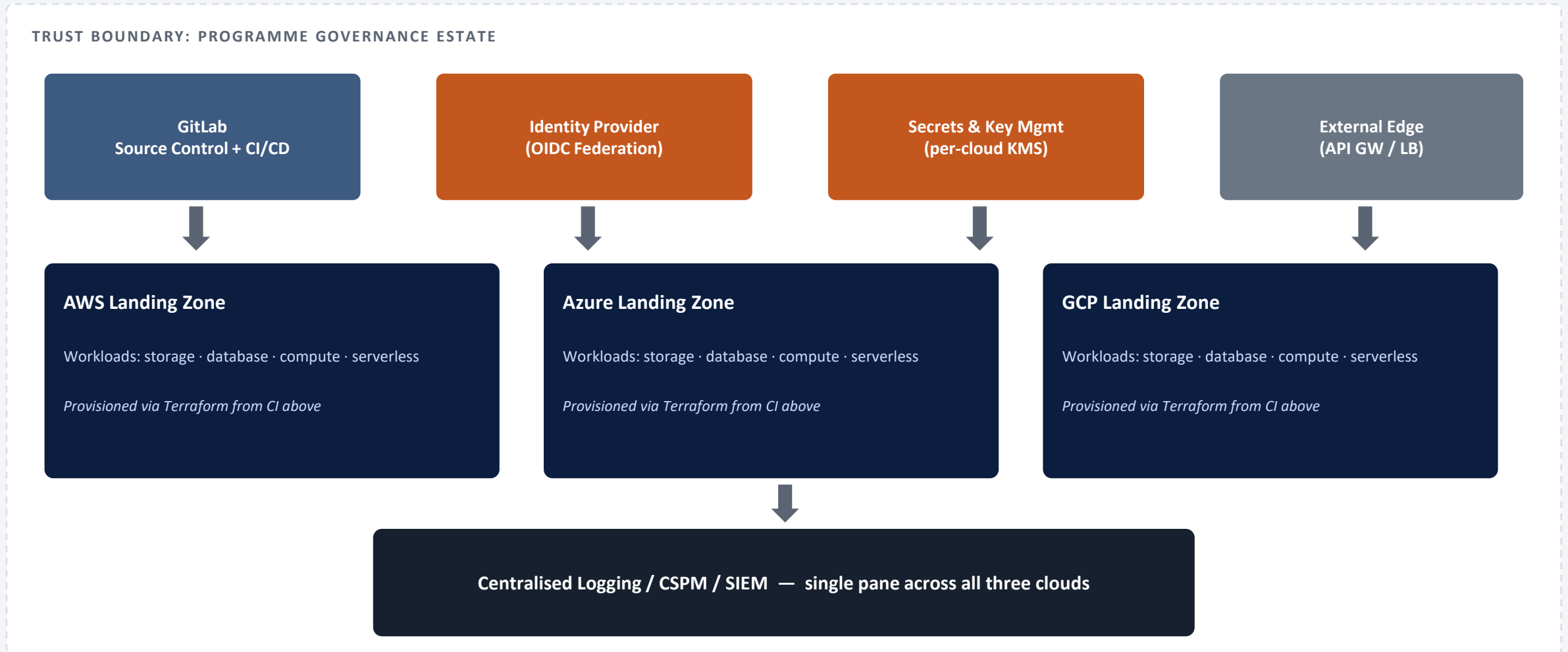
Example cadence: T+0 detected → T+15 contained → T+30 first stakeholder update → T+4h eradication confirmed

POST-INCIDENT REPORT

Full timeline, root cause (the wildcard policy), blast radius actually reached vs. possible, remediation completed, and the control change that prevents recurrence — tied back to the pipeline redesign in Module 2, not a one-off fix.

Distributed to governance board and delivery leads within 5 working days of closure.

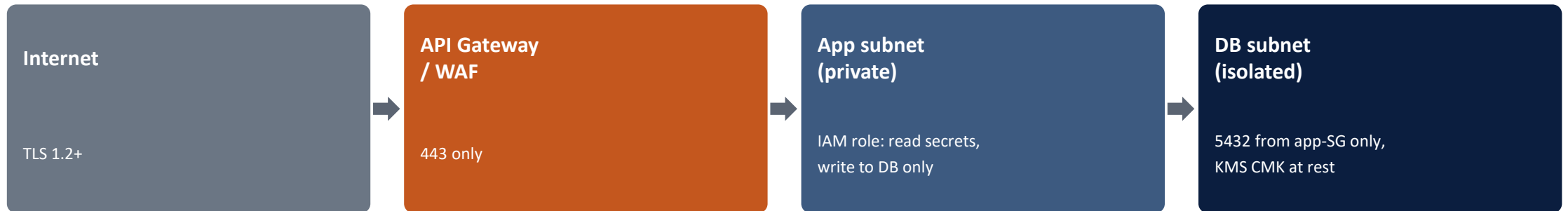
Target-State Design — System Context



Full narrative and rejected alternative (single shared KMS across clouds) in *architecture-narrative.md*.

One Slice, Implementable: Ingress → App → Database

CI/CD provisioning path: GitLab job → OIDC → deploy-role (scoped: tf plan/apply on tagged VPC + RDS resources only) → Terraform apply



Encryption & secrets

In transit: TLS end-to-end, edge to DB. At rest: provider-native KMS CMK on the DB volume and its snapshots. App reads DB credentials from Secrets Manager/Key Vault-equivalent at runtime via its IAM role — never from environment variables baked into the image.

Detection tooling placement

CSPM agent evaluates this account's config continuously against the OPA policy set. VPC flow logs from both subnets and the DB's audit log stream to the central SIEM shown on the HLD — not stored only locally in this account.

The COTS Exception — What We're Asking You to Accept

The financial reconciliation tool's connection driver cannot operate with storage encryption enabled, and it cannot be re-platformed before the compliance deadline. Encryption-at-rest cannot be the control here — so three compensating controls carry the risk instead.

1

Network isolation

Moved into its own isolated subnet with no route to any other workload; access restricted to named admin IPs only (from Module 4's segmentation model).

2

Enhanced logging & monitoring

Every read/write to the underlying storage is logged and streamed to the SIEM in near-real-time, with anomaly alerting tuned specifically for this workload (Module 6).

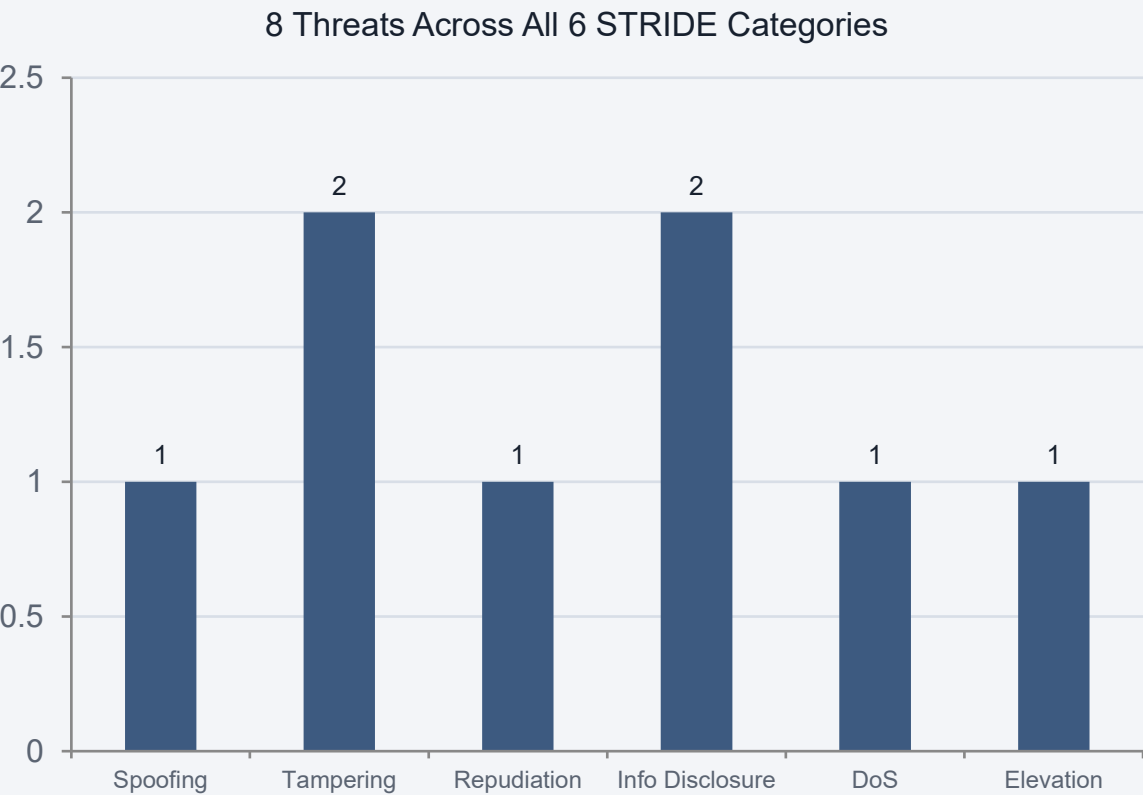
3

Compensating access control

Just-in-time, approval-gated access only — no standing credentials, session recording enabled for anyone touching the data store.

Residual risk: Medium (post-controls), time-bound. Formal acceptance requested from the governance board, valid for 2 quarters pending vendor re-platforming or driver update. Reviewed again at each quarterly compliance checkpoint. This exception is scoped to this workload only — it does not extend automatically to other COTS products in the estate; each would require its own risk assessment.

STRIDE on the Public-Facing Web + Database Workload



Representative threat: Elevation of Privilege

Likelihood: Medium · Impact: High
App-tier IAM role could be escalated via a misconfigured trust policy to reach the DB tier directly. Control: scoped role + explicit deny on iam:PassRole outside its own service boundary (Module 3).

Honest residual: Repudiation gap

Application-layer actions (not infra API calls) are not yet individually attributable to an end user in audit logs. Existing controls do not fully mitigate this — flagged as residual risk, with app-level audit logging as a backlog item rather than an unstated gap.

A Mapping Methodology, Not a Clause-Number Exercise

Finding	Plausible Compliance Domain	Evidence to Gather
Public storage bucket	Access control	Screenshot + IaC diff pre/post-fix, CSPM scan result
DB unencrypted + public	Encryption / access control	KMS key policy, network reachability test, config export
Wildcard CI IAM policy	Access control / least privilege	Policy diff, access-review sign-off, CI run logs
Inconsistent audit logging	Logging & monitoring	Trail coverage report across all accounts, SIEM ingestion proof
Hardcoded secret in code	Secrets management	Git history scan result, rotation record, Gitleaks gate evidence

Consistency layer: a single OPA/Conftest policy set expresses each control once (e.g. "no public storage") and is evaluated against AWS, Azure and GCP resource definitions alike — one rule, three enforcement points, instead of three drifting rule sets.

Security That Assumes Things Will Also Need to Come Back Up

4 hrs

RTO

representative Tier-1 workload

15 min

RPO

via continuous transaction log shipping

~90%

Recoverable from Git

of target state is code, not console clicks

Backup approach by resource type

Storage: versioning + cross-region-within-jurisdiction replication. Databases: automated encrypted snapshots + point-in-time recovery. Compute: immutable images rebuilt from Terraform + CI artefact registry, not backed up as running state.

Cross-cloud failover: not the default

Argued position: cross-cloud DR adds significant complexity (data sync, identity, network) for workloads that don't need that level of resilience. Resilience is addressed within a single provider using multi-region/multi-AZ patterns by default; true cross-cloud failover is reserved for the handful of workloads whose business impact analysis justifies it — not assumed just because the estate is multi-cloud.

The First Stretch of This Programme

Weeks 1–2

Stop the bleeding

Remediate the 4 critical findings or formally risk-accept; ship the pipeline's hard-fail gates (secrets, IaC, policy-as-code).

Weeks 3–6

Govern the rest

Roll CSPM + central logging across all AWS accounts; land the identity redesign (OIDC federation, CI role scoping) estate-wide.

Weeks 7–10

Prove it holds

Compliance mapping evidence collected for go-live sign-off; COTS exception formally accepted with residual risk plan on record.

Weeks 11–13

Multi-cloud on-ramp

Azure/GCP landing zones stood up against the same HLD; pipeline gates extended with provider-specific rule packs — same model, new provider.

WHAT WE NEED FROM THIS PANEL TODAY

Three Decisions, Then We Get to Work

1

Accept the COTS residual risk

Medium rating, 2-quarter window, compensating controls in place from day one.

2

Sponsor the pipeline & identity redesign

Cross-cutting — blocks recurrence of all four critical findings at once.

3

Confirm the go-live scope

Sampled workloads sign off this quarter; full estate rollout tracked on the 90-day plan.

Thank you — happy to take questions.

Full detail behind every slide: [devsecops-assessment-track2](#) repository, modules 01–13.